

Abdi Abera

Lab - Investigating OWASP

Objectives

Part 1: OWASP Top 10

Part 2: OWASP Community Pages

Background / Scenario

[Open Web Application Security Project \(OWASP\)](https://owasp.org/) is a non-profit organization that is dedicated to web application security. OWASP publishes a list of the Top 10 most critical web security concerns facing organizations about every three years. The objective of this report is to raise awareness regarding web application security and to help organizations incorporate this information into their process to minimize and mitigate security risks.

OWASP also accepts community contributions for security related content. The [OWASP Community Pages](#) provides list of attacks and vulnerabilities reported by the communities.

In this lab, you will explore the OWASP Top 10 from 2021 and a few of the attacks and vulnerabilities reported by community contributors.

Required Resources

= Internet access

Instructions

Part 1: OWASP Top 10

- Navigate to the OWASP Top 10 (<https://owasp.org/Top10>).
- At the time of this writing, the draft of latest list of Top 10 was published in 2021.

Review the Top 10 categories. Pick 3 categories out of the Top 10. In the table below, list your chosen categories. Then briefly describe the category and some of the ways to prevent attacks in the category.

Top 10 Category	Description	Prevention
Injection	infected data is sent like SQL as part of command then fooling the system into executing not permitted action	we have to validate all user supplied data or we have to use 'stored Procedure' instead of inputting raw data.
Security Misconfiguration	open cloud storage, insecure settings.	we have to change all password to strong passwords, also by removing unused features /services.

Top 10 Category	Description	Prevention
Broken Access Control	users can access data without the permission and seeing other users activity	we have to use centralized access control (CAN) modules.

Part 2: OWASP Community Pages

The OWASP Community Pages allows security-related contributions from the community. In this part, you will review the Vulnerabilities pages to investigate the attack techniques reported by the contributors.

- Navigate to the OWASP Community Page for Vulnerabilities.

(<https://owasp.org/www-community/vulnerabilities/>).

OWASP defines a vulnerability as flaw in the application that a threat actor can exploit.

Review the List of Vulnerabilities and pick 3. In the table below, list your chosen vulnerabilities. Briefly describe the vulnerability and some of the ways to prevent exploitation.

Vulnerabilities	Description	Prevention
cross site	its easy to inject malicious into trusted websites executed in user website	we have to implement security policy on the content we had
buffer overflow	sometimes when software got write the code it gonna hold and learning the system into crashes	implement input validation
insecure direct object reference (IDOR)	access to the system without authorization	verify the permission

- Navigate to the OWASP Community Page for Attacks. (<https://owasp.org/www-community/attacks>).

According to OWASP, an attack is a technique used to exploit application vulnerabilities.

Review the **List of Attacks** and pick 3. In the table below, list your chosen attacks. Then briefly describe the attack and some of the ways to prevent it.

Attacks	Description	Prevention
Man in the Middle (MitM)	being on the middle and intercept and alter the communications	using ssh and enforce https/tls for all web traffics
SQL Injection	this is malicious SQL statement inserted to entry field (for execution)	We have to use validation input

Attacks	Description	Prevention
Brute Force Attack	this the way automated techniques used to discover passwords or even they can encrypt keys.	we can use MFA and account lockout after some failed tries or attempts